



Re: technical report done for milestone 2

From sagar dake <sagar.dake980@gmail.com>
Date Tue 04/11/2025 09:13
To Gareth Farry <gareth.farry@amnesty.org.nz>
Cc Brian Cusack <brian.cusack@aut.ac.nz>

Hi Gareth,
I hope you are doing well.

As discussed, I've reviewed the current Plutus/Aiken smart contract implementation that you would like to integrate into your project (Task 2). Please note that **Task 2 was not originally part of the testing scope**, but I've included this additional review to help strengthen the system before broader deployment.

I should also mention that my comments are based on the **available partial source code**. Some Plutus report sections could not be fully tested due to **missing dependencies and incomplete datasets**. Therefore, certain observations may not reflect the final integrated system with 100 percent accuracy.

That said, my goal here is to provide **constructive technical feedback** to help the system evolve safely, improve performance, and scale effectively on a global level. The findings below highlight potential improvement areas and recommended mitigation options.

Task 2 – Smart Contract Technical Review & Observations

1. Data Model & Serialization Issues

- **Dict serialization flaw:** Dict types are not directly serializable on-chain; this may cause decoding errors.
Fix: Use Pairs<ByteArray, Int> for storage and reconstruct the Dict during validation.
- **Key-ordering dependency:** Ensure deterministic ordering to prevent hash mismatches.
Fix: Pre-sort keys and expand boundary tests.

2. Incentive Logic & Token Categorization (I understand you didn't cover this part in Plutus but with this solution you can implement it)

- Current UTY tokens are fungible; categories such as "education = 5" or "health = 2" cannot be enforced.
Fix options: mint category-specific tokens (UTY:EDU / UTY:HLT / UTY:PRS), use CIP-68 metadata, or lock tagged UTxOs.

3. Faucet Abuse & Sybil Resistance

- The 5-token signup reward can be exploited via multiple wallets.
Mitigation: Add a registry UTxO, oracle-signed proof-of-personhood, and backend rate-limiter.

4. Access Control & Mint Policy Governance

- Single-key minting is risky.
Fix: Adopt k-of-m multisig, add timelock and emergency pause, and store admin keys in an Oracle Registry.

5. Replay / Double-Spend / Nonce Management

- Missing nonce validation allows replay attacks.
Fix: Include nonces in redeemers and maintain a nonce_registry UTxO.

6. State Growth & Concurrency

- Accumulating records in one state UTxO will exceed Plutus B-limits.
Fix: UTxO sharding, capped map sizes, and batch-update design.
- For >10 million users, horizontal scaling via multiple validators + Hydra heads is advised.

7. Arithmetic & Merge Strategy

- Risk of integer overflow and negative balances.
Fix: Clamp all results ≥ 0 and add property-based fuzz tests.

8. Front-Running & Transaction Binding

- Attackers could alter outputs before confirmation.
Fix: Bind output and datum hashes in redeemer; use deterministic outputs or commit-reveal pattern.

9. Governance Layer

- One-token-one-vote model may lead to governance capture.
Fix: Quadratic voting, quorum, veto, and staged execution windows.

10. Compliance & Recovery

- Lost keys currently mean irrecoverable tokens.
Fix: Define policy choice—immutability vs. controlled multisig recovery.

11. Continuous Integration & Testing

- Current CI runs only formatting and syntax checks.
Fix: Add unit/property/fuzz tests and adversarial simulations.

12. Scalability & Global Readiness

- Base layer $\approx$ 60 TPS; not enough for billions of events.
Recommendation: Adopt Layer-2 (Hydra, Mithril, Rollup) and batch oracles for settlement.

The smart contract works well for pilot or local testing but needs the above improvements before a global rollout. Key priorities include serialization, access control, nonce management, category allocation, and scalability. All fixes are achievable within Aiken/Plutus V2 using multisig policies, bounded UTxOs, and off-chain aggregation.

Please take these notes in the spirit intended to strengthen reliability, security, and scalability of your system. I'm happy to collaborate further once the remaining dependencies and complete Plutus sources are available.

On Fri, Oct 31, 2025 at 10:45 AM Gareth Farry <gareth.farry@amnesty.org.nz> wrote:

Contracts to audit, plus one page document to fill in (or amend for your own reporting requirements).

Technical report here -

<https://docs.google.com/document/d/1Na7hGDy1MLVBWi4STN0gsdtLFmCQJAKd-w-3UyhS9Vg/edit?tab=t.0>

Please keep audit light touch, but also identifying any issues in future to deal with such as what you have already mentioned with scalability

Thanks!

Gareth Farry | Partnerships and Special Projects Manager | **Amnesty International Aotearoa New Zealand**
m: 021 657 497 | p: 0800 AMNESTY (266 378)
gareth.farry@amnesty.org.nz | amnesty.org.nz | Charities Commission Registration number: CC35331

[What's your vision for humanity? We'd love to hear it.](#)